Bloque 1: Introducción, Gobernanza y el Ciclo de Desarrollo Seguro

FADENA

Introducción a la Seguridad en el Software y DevSecOps

Ing. Roxana Quiroga Sollinger



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

1.1 El software funciona, pero ¿es seguro?

1.2 ¿Por qué falla el software?

1.3 El costo real de la inseguridad

1.4 El SDLC tradicional y la seguridad tardía

1.5 De Agile a DevOps

1.6 DevSecOps: integrar seguridad

1.7 CAMS: Culture y Automation

1.8 CAMS: Mesurement y Sharing

1.9 La seguridad como proceso continuo



Módulo 1: Fundamentos de Seguridad en el Software

FADENA

¿Por qué falla el software?



1.2 ¿Por qué falla el software?

FADENA

- Del error humano a la falla del software
- Fallas originadas en los requisitos
- Ciclo de vida del software
- Arquitectura y sus impactos en el área técnica
- Fallas originadas en los requisitos
- Comportamiento de los requisitos de atributos de calidad
- Complejidad creciente del código fuente
- Del defecto técnico a la vulnerabilidad: amenaza, riesgo e impacto
- ¿Qué es el software seguro?



1.2 ¿Por qué falla el software?

Del error humano a la falla del software

Un aspecto central y crítico del problema de la seguridad informática es un problema de software. El software contiene defectos que afectan su seguridad.

El software moderno es uno de los sistemas más complejos creados por el ser humano. Se encuentra presente en infraestructuras críticas, sistemas financieros, salud, transporte, telecomunicaciones y prácticamente cualquier actividad económica.



COMPLEJIDAD EXTREMA

Millones de líneas de código hacen inevitable la existencia de fallos.

DEL PERÍMETRO AL CÓDIGO

Los atacantes no rompen el firewall; explotan errores de diseño e implementación.

RIESGO SISTEMICO

Un fallo en el software expone infraestructura crítica (finanzas, salud, energía y redes).

FADENA

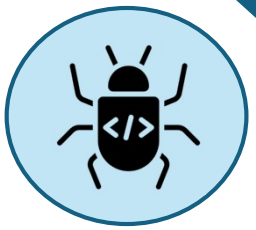
1.2 ¿Por qué falla el software?

Del error humano a la falla del software



Error

Acción humana que produce un resultado incorrecto.



Bug

Error de programación o implementación que provoca un comportamiento incorrecto del software. Generalmente es un error puntual en el código.



Defecto

Imperfección o deficiencia presente en un producto de trabajo del desarrollo del software.



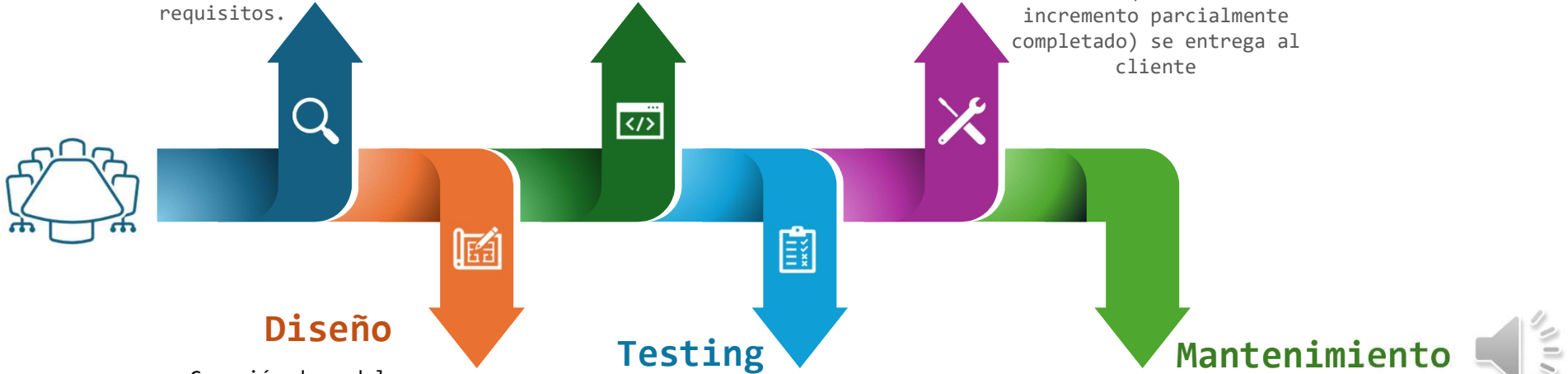
Falla de diseño

Problema conceptual o arquitectónico que surge durante el análisis o diseño del sistema.

FADENA

1.2 ¿Por qué falla el software?

Ciclo de vida del software



Análisis

Colaboración entre partes. De la idea a los requisitos.

Diseño

Creación de modelos para comprender mejor los requisitos del software y el diseño que los satisfaga.

Desarrollo

Codificación del software.

Testing

Etapa de validación y verificación del software.

Despliegue

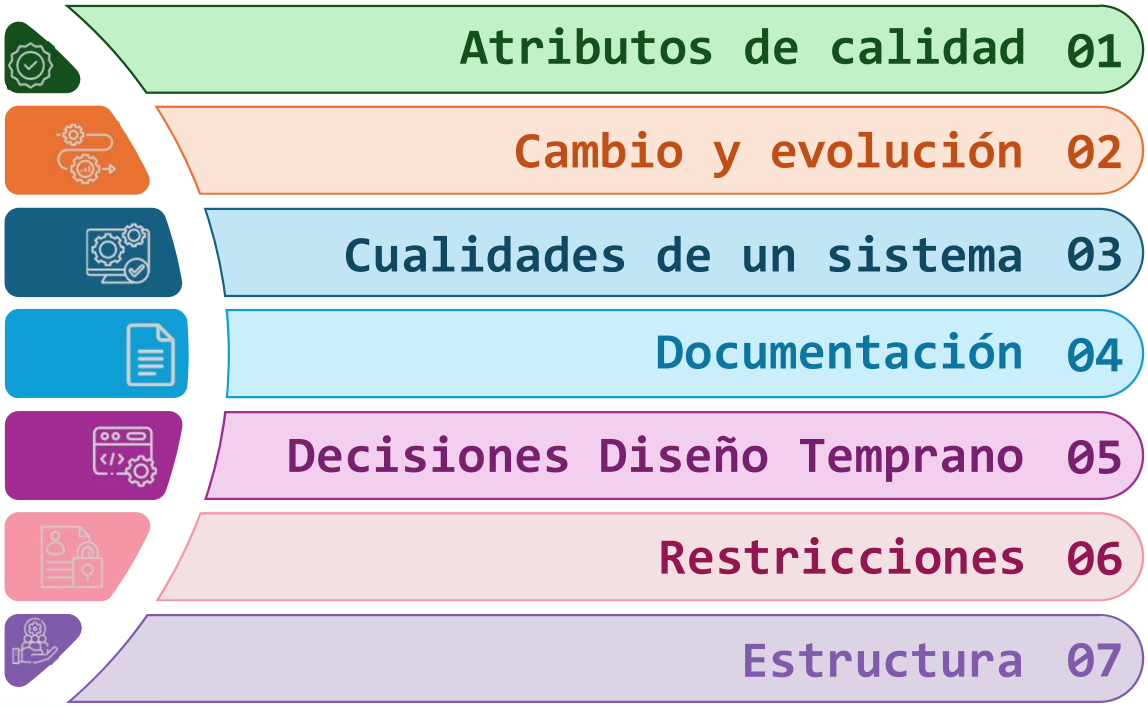
El software (como una entidad completa o como un incremento parcialmente completado) se entrega al cliente

Mantenimiento

Correcciones del código fuente y actualización de sus dependencias.

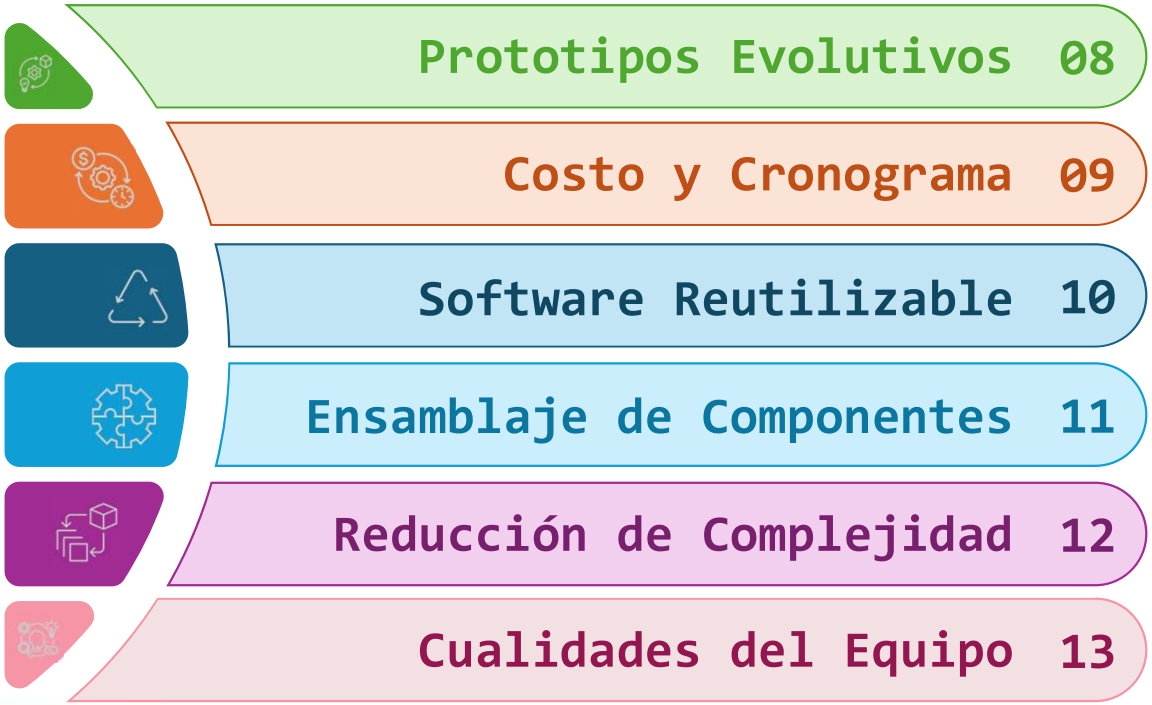
1.2 ¿Por qué falla el software?

Arquitectura y sus impactos en el área técnica



1.2 ¿Por qué falla el software?

Arquitectura y sus impactos en el área técnica



1.2 ¿Por qué falla el software?

Fallas originadas en los requisitos



Verificable

Según el glosario de ISTQB un sistema es verificable cuando un proceso puede confirmar que el producto cumple con su especificación.

Objetivo

Debe ser cumplido o poseído por un sistema para resolver un problema de las partes interesadas o para lograr un objetivo de las partes interesadas.

Medible

El requisito está cualificado por condiciones medibles y limitado por restricciones.

Rendimiento

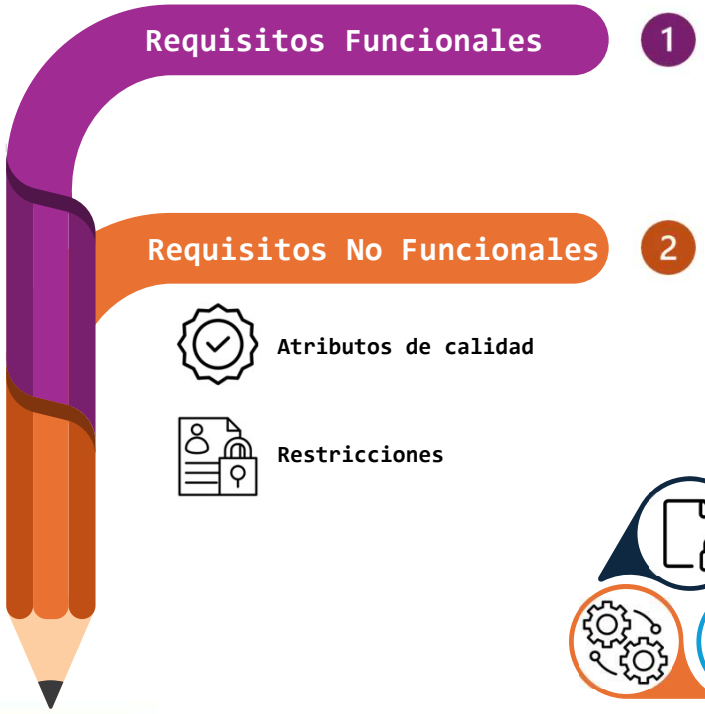
Define el rendimiento del sistema cuando lo utiliza un interesado específico o la capacidad correspondiente del sistema, pero no la capacidad del usuario, operador u otro interesado.

FADENA

1.2 ¿Por qué falla el software?

Fallas originadas en los requisitos

Arquitectura y requisitos



Requisitos Funcionales

Los requisitos funcionales describen las funciones o tareas que el sistema o los elementos del sistema deben realizar.

Requisitos No Funcionales

Estos requisitos especifican las condiciones bajo las cuales el sistema debe operar o existir, así como sus propiedades. Definen cómo debe ser un sistema. Los requisitos de calidad y los requisitos de factores humanos son ejemplos de este tipo.



- **Confidencialidad**
- **Integridad**
- **Disponibilidad**
- **Autenticidad**
- **No repudio**
- **Resistencia**

FADENA

1.2 ¿Por qué falla el software?

Comportamiento de los requisitos de atributos de calidad



Estímulo

Condición que requiere una respuesta cuando llega a un sistema

Artefacto

Parte del sistema que aplica el estímulo. e.g.: almacenamientos, procesos, transporte, etc.

Respuesta

La respuesta es la actividad emprendida como resultado de la llegada del estímulo.
Previene que la respuesta genera una falla de estímulo en dos etapas:

1. Detección de falla
2. Corrección y/o recupero de fallas



Fuente de estímulo

Entidad que generó el estímulo que puede ser interno o externo como un atacante, una persona, un requisito u otro sistema. También puede ser otro software, infraestructura interna o externa e incluso proveniente del ambiente externo.

Medio ambiente

El ambiente actúa como un calificador en el estímulo. Como operación normal, startup, shutdown, modo reparación.

Medida de la Respuesta

Cuando se produce la respuesta, debe ser medible de alguna manera para que el requisito pueda ser probado.



FADENA

1.2 ¿Por qué falla el software?

Complejidad del código fuente

Origen del Problema



Todo defecto en el código es una vulnerabilidad potencial

Impacto Crítico



Controla finanzas, salud, transporte, telecomunicaciones y la economía global.

Explosión de complejidad



La explosión de complejidad del software moderno se debe a que la suma constante de nuevos componentes multiplica exponencialmente la posibilidad de fallos en sistemas críticos.

Efecto Multiplicador



Efecto multiplicador: + Componentes e interacciones = Crecimiento exponencial de errores.

1.2 ¿Por qué falla el software?

Complejidad del código fuente

Conectividad

La mayoría de las tareas suceden online. Al estar conectados a Internet, los sistemas se vuelven vulnerables a ataques informáticos provenientes de fuentes remotas.

Fallo en cascada: La conectividad convierte un fallo local en un colapso sistémico al actuar como el canal que propaga, amplifica y oculta el origen de las fallas a través del sistema.

Acoplamiento: La conectividad describe cuántas relaciones existen entre los componentes de un sistema, mientras que el acoplamiento describe cuán dependientes son esos componentes entre sí.

Extensibilidad

Según la norma ISO/IEC 25010, la ***extensibilidad*** suele considerarse una subcaracterística asociada a la mantenibilidad, en particular a la ***modificabilidad***.

La ***extensibilidad*** del software es la capacidad de un sistema para incorporar nuevas funcionalidades, componentes o comportamientos con un impacto mínimo en el código existente y sin comprometer su funcionamiento, calidad o arquitectura. Es una propiedad fundamental de los sistemas que deben evolucionar a lo largo del tiempo

Complejidad

Límites cognitivos: La complejidad en el software es un peligro conocido desde hace décadas. La estrategia no esr procesar sistemas masivos, sino reducir activamente su complejidad.

Impacto directo en errores: La complejidad del flujo de control se vincula directamente con fallos frecuentes y baja confiabilidad.

Evidencia práctica: Casos reales demuestran que utilizar métricas para medir y controlar la complejidad reduce drásticamente las tasas de defectos posteriores al lanzamiento.

FADENA

1.2 ¿Por qué falla el software?

Del defecto técnico a la vulnerabilidad: amenaza, riesgo e impacto

Amenaza

Circunstancia desfavorable que puede ocurrir y que cuando sucede tiene consecuencias negativas sobre los activos provocando su indisponibilidad, funcionamiento incorrecto o pérdida de valor. Una amenaza puede tener causas naturales, ser accidental o intencionada

Vulnerabilidad

Debilidad en un sistema de información, procedimientos de seguridad del sistema, controles internos o implementación que podría ser explotada o activada por una fuente de amenaza.

Riesgo

Una medida del grado en que una entidad se ve amenazada por una circunstancia o evento potencial, y que generalmente depende de:

(i) los impactos adversos que surgirían si la circunstancia o el evento ocurriera;

(ii) la probabilidad de ocurrencia

Impacto

La magnitud del daño que cabe esperar como consecuencia de la divulgación no autorizada de información, la modificación no autorizada de información, la destrucción no autorizada de información o la pérdida de información o de la del sistema de información.

Definiciones según el glosario NIST

FADENA

1.2 ¿Por qué falla el software?

Del defecto técnico a la vulnerabilidad: amenaza, riesgo e impacto

Amenaza

Circunstancia desfavorable que puede ocurrir y que cuando sucede tiene consecuencias negativas sobre los activos provocando su indisponibilidad, funcionamiento incorrecto o pérdida de valor. Una amenaza puede tener causas naturales, ser accidental o intencionada

Vulnerabilidad

Debilidad de un activo o de un control que puede ser explotada por una o más amenazas

Riesgo

Potencial de que una amenaza específica explote las debilidades de un activo o grupo de activos para ocasionar pérdida y/o daño a los activos. Por lo general se mide por medio de una combinación del impacto y la probabilidad de ocurrencia (CCN, 2015, pág. 756).

Impacto

Consecuencia que sobre un activo tiene la materialización de una amenaza

Definiciones según el glosario Resolución 1523 / 2019, Anexo II

1.2 ¿Por qué falla el software?

¿Qué es el software seguro?

Software Seguro



Confiabilidad

No existen vulnerabilidades ni debilidades explotables, ya sean de origen malicioso o no intencional.

Ejecución predecible

Existe una confianza justificada en que el software, al ejecutarse, funcione según lo previsto

Conformidad

Un conjunto planificado y sistemático de actividades multidisciplinarias garantice que los procesos y productos de software cumplan con sus requisitos, estándares y procedimientos.

FADENA

1.2 ¿Por qué falla el software?

¿Qué es el software seguro?

Propiedades que influencian la seguridad del software

Confiabilidad

Garantiza que el software funcione siempre según lo previsto.

Corrección

Asegura que el software funcione según lo previsto en condiciones normales.

Previsibilidad

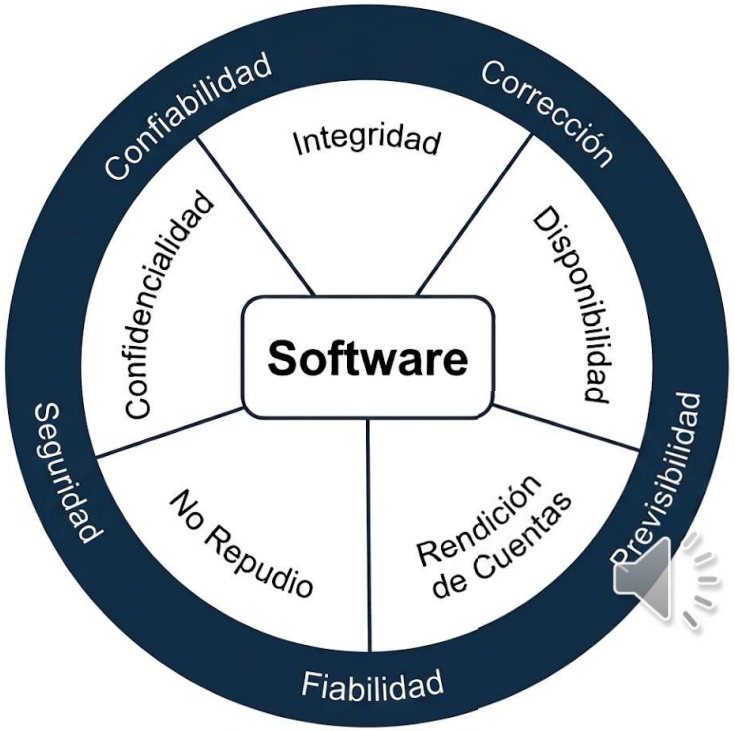
Implica que la funcionalidad, las propiedades y el comportamiento del software siempre serán los esperados.

Fiabilidad

Preservar una ejecución predecible y correcta a pesar de la presencia de defectos no intencionados.

Seguridad

Propiedad afectada por el código.



FADENA

1.2 ¿Por qué falla el software?

¿Qué es el software seguro?

Seguridad del Software

La capacidad de un equipo de desarrollo de software para manipular las propiedades de seguridad del software se reduce a un equilibrio entre la defensa y el pensamiento de un atacante.

Atacante

Intenta comprender las debilidades del producto para explotarlas.

Defensor

Trabaja para incorporar al software las características de seguridad adecuadas.

